LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Not: liste PaketPro'ya göredir; VMGS 2504 için NC/IoT eklenmiş varsayımıyla gruplandı. Z1 Emniyet bölgesi (en kritik): Emniyet PLC'si/emniyet rölesi, kafes-kapak kilidi, acil stop, motor kontaktörü. Z2 Kontrol bölgesi: Üretim PLC (NC arka dayama), HMI, motor sürücüleri. Z3 Servis/DMZ: uzak bakım modülü, servis hesabı, kilitsiz USB (kontrollü). Z4 Dış/Kurumsal: bulut telemetri, Wi-Fi AP.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Z3 (servis/DMZ) bölgesine düşer ve Z1/Z2'de KALAMAZ: internete doğrudan açık olduğu için güvenilmeyen ağla temas eder; Z2/Z1'e doğrudan bağlıysa tek bir ihlalle bıçak kumandası ele geçirilir. Yalnızca conduit üzerinden (jump server + VPN + MFA), varsayılan kapalı ve kayıtlı erişim verilir.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

Conduit'ler: Z4→Z3 (internet/Wi-Fi → servis): güvenlik duvarı, VPN, MFA, kimlik, kayıt. Z3→Z2 (servis → kontrol): yalnızca izinli protokol/port, onaylı bakım penceresi, parametre değişikliği kaydı. Z2→Z1 (kontrol → emniyet): tek yönlü/minimum sinyal, emniyet fonksiyonunu geçersiz kılma yok; Z1'e uzaktan erişim yok.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: doğrudan bağlantı yok; NC/servis erişimi tek denetlenen noktadan geçer.
Tünel?	Açık / VPN	VPN: açık internete servis portu açılmaz; şifreli tünel yalnızca servis bölgesine.
Kimlik?	Parola / MFA	MFA: tek parola yetmez; ele geçirilirse bıçak kumandası riski doğar.
Hesap?	Paylaşılan / Kişisel	Kişisel: admin/admin ve paylaşılan hesap kaldırılır; kim ne yaptı izlenir.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: kim, ne zaman, hangi parametreyi değiştirdi; olay delili.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: bakım penceresinde açılır, iş bitince kapanır; çalışırken uzaktan müdahale yok.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.